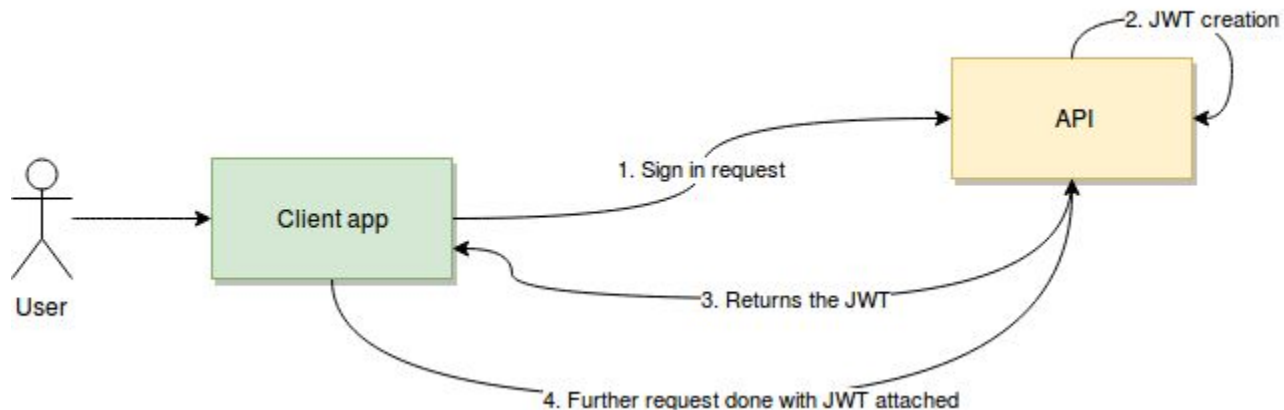




Manejo de Tokens en API REST con JWT

Qué es JWT? Jason Web Tokens son un estándar abierto (RFC7519) para la representación de identidad de usuario en una interacción de dos partes. De esta manera, cuando dos sistemas intercambian información, se puede utilizar un token JWT para identificar al usuario sin la necesidad de intercambiar credenciales con cada interacción.

Manejo de Tokens en API REST con JWT





Manejo de Tokens en API REST con JWT

Estructura de los tokens:

HEADER.PAYLOAD.SIGNATURE



Manejo de Tokens en API REST con JWT

HEADER: contendrá información relacionada con el tipo de token que se está generando, así como del algoritmo utilizado para su generación. Hay muchos algoritmos compatibles, pero los más comunes son HS256 y RS256. Dependerá de los estándares de seguridad y medidas necesarias. Un caso común es utilizar una clave secreta conocida por el cliente y el servidor, y otra alternativa es utilizar una clave secreta conocida por el servidor en combinación con una clave pública conocida por el cliente



Manejo de Tokens en API REST con JWT

PAYLOAD: contiene información perteneciente al requerimiento y al usuario que lo efectúa. Hay un conjunto de pares clave-valor que son definidos como parte de JWT y que se pueden utilizar en la implementación, tales como:

- Issuer: la manera de identificar al usuario que hace el request
- Subject: es el motivo del request. Suele ser la URI
- Audience: intenta proveer identificación del recipiente del token
- Fecha de expiración.



Manejo de Tokens en API REST con JWT

SIGNATURE: es un string codificado, usado por el cliente y el servidor para verificar la autenticidad del payload.



Manejo de Tokens en API REST con JWT

Modo de uso:

- Primer paso: la autenticación. Es necesario loguearse ejecutando un método de la API para tal fin. Se envían como parte del payload las credenciales del usuario para loguearse. Con ellas se correrá el algoritmo para la generación del token
- El método genera el token considerando cada una de las partes que conforman el payload de retorno.



Manejo de Tokens en API REST con JWT

Header:

```
{  
  "alg": "HS256",  
  "typ": "JWT"  
}
```

Payload:

```
{  
  "Iss": "fernando"  
  "Exp": 1550946689,  
  "Admin": false  
}
```



```
Base64(payload) =
```

```
HS256(Base64(header) + "." + Base64(payload), "A secret API example") =
```

TseARzVBAtDbU8f3TEiRgsUoKYaw2SbhCWB0QlKpdp8

```
ewoiYWxnIjogIkhTMjU2liwKInR5cCI6ICJKV1QiCn0K.ewoiSXNzIjogImZlcm5hbmRvIiwKIiV4cCI6IDE1NTA5NDY2ODksCiJBZG1pbiI6IGZhbHNlCn0K.TseARzVBAtDbU8f3TEiRgsUoKYaW2SbhCWB0QlKpdp8
```



Manejo de Tokens en API REST con JWT

La aplicación cliente que recibe este token puede descifrarlo y validarlo mediante sus secciones de header y payload y firmarlas por su cuenta (tanto el cliente como el servidor conocen la frase secreta). De esta manera se pueden asegurar que nadie cambió el contenido.

Cualquier requerimiento posterior enviado por el cliente va a contener este token, el cual va a ser validado por el servidor mediante su refirmado cada vez, y su comparación con la porción de firma del token.



Manejo de Tokens en API REST con JWT

Con este mecanismo, la securización de una API Rest no se vuelve tan complicado. Y JWT tiene implementaciones para muchos lenguajes y variantes de implementación para distintas necesidades.

Agregar solo JWT como mecanismo de securización de una API nunca es suficiente. Deben aplicarse todas las prácticas de seguridad previamente mencionadas.